

ITCloser Internship — Cybersecurity Squad 8824

# Comparative Security Analysis of NFC & Bluetooth Protocols

*Attack Vectors, Risk Profiles & System Hardening — 2026 Edition*

**Project Category**  
Cybersecurity — System Hardening & Risk  
Assessment

**Report Date**  
March 2026

**Focus Area**  
NFC & IoT Wireless Risk Assessment  
(Project E)

**Framework Reference**  
OWASP IoT Top 10 (I3, I5, I9)

PREPARED BY — CYBERSECURITY SQUAD 8824

**Adedamola Oladeinde**

Hannah Bello · Christopher Awe · Eyitayo Afolabi · Olaoluwa Owoade  
Abdulsamad Animashaun · Abdulmalik Oyelowo · Taiwo Adesiyon · Feranmi Abiola  
Khalid Olatunji · Oladeji Olakunle · Daniel Alfred · Sangolade Joy Adeola  
Ogunsola Testimony · Babalola Mahmud · Umar Muhammed Aliy

## 1. Executive Summary

---

This report delivers a deep-dive security analysis comparing Near Field Communication (NFC) and Bluetooth as deployed across consumer payments, access control, smart devices, and enterprise IoT infrastructure as of 2026. Drawing on real-world attack data from ESET, Kaspersky, Zimperium, Cyble, and peer-reviewed academic research, it evaluates both protocols across dimensions of architecture, known vulnerabilities, active threat campaigns, and organisational risk.

The core finding is that while NFC has long been considered the safer short-range protocol owing to its physical proximity requirement, the threat landscape shifted dramatically in 2025–2026. The weaponisation of open-source relay tools (NFCGate, NFCSkate) and the emergence of Malware-as-a-Service platforms (SuperCard X, RelayNFC, RatOn) have partially eroded NFC's primary security advantage. NFC attacks reported by ESET telemetry surged more than 35 times between H2 2024 and H1 2025.

Bluetooth remains the higher-risk protocol overall, with a broader persistent attack surface, multiple specification-level vulnerabilities (KNOB, BIAS, Method Confusion), and a 2025 disclosure of critical hardware flaws affecting major consumer headphone brands. The risk ranking by protocol variant, from highest to lowest, is: Bluetooth Classic > Bluetooth Low Energy > NFC (contactless payments) > NFC (passive tags).

## 2. Technical Architecture & Security Foundations

---

### 2.1 Near Field Communication (NFC)

NFC operates at 13.56 MHz and is defined by ISO/IEC 14443 and ISO/IEC 18092. Its effective communication range is typically under 4 centimetres, though advanced antenna setups can extend eavesdropping range to approximately 1 metre under ideal conditions. Three operating modes exist:

- Reader/Writer mode — device reads or writes to passive NFC tags.
- Peer-to-peer mode — two active NFC devices exchange data bidirectionally (used in Android Beam and similar).
- Card emulation mode — a device mimics a contactless smart card; Host Card Emulation (HCE) allows this entirely in software, while hardware-backed Secure Element (SE) implementations store cryptographic credentials in tamper-resistant silicon.

**Security principle:** NFC's core security is described as 'Security by Proximity.' The sub-4 cm operational range creates a natural physical barrier that makes remote, opportunistic attacks extraordinarily difficult. Payment systems layer tokenisation (EMVCo standards) on top: the actual Primary Account Number (PAN) is never transmitted; instead a one-time cryptographic token is used, making transaction replay attacks impractical.

## 2.2 Bluetooth Classic (BR/EDR)

Bluetooth Classic (Basic Rate / Extended Data Rate) operates in the 2.4 GHz ISM band using frequency-hopping spread spectrum across 79 channels, cycling approximately 1,600 times per second. Class 1 devices reach 100 metres; Class 2 reach 10 metres. Security is negotiated through the Link Manager Protocol (LMP), with Secure Simple Pairing (SSP) introduced in Bluetooth 2.1 to replace the vulnerable legacy PIN-based pairing.

**Critical flaw:** The LMP key negotiation process is not itself encrypted. This means the session key length — which should be 16 bytes — can be downgraded to as few as 1 byte by a man-in-the-middle attacker without either device detecting the tampering. This is the basis for the KNOB attack (CVE-2019-9506), which affects all standard-compliant Bluetooth Classic devices.

## 2.3 Bluetooth Low Energy (BLE)

BLE was introduced in Bluetooth 4.0 to serve power-constrained IoT devices — sensors, wearables, beacons, and medical devices. It operates on 40 channels at 2.4 GHz and uses AES-128 encryption in LE Secure Connections (introduced in Bluetooth 4.2 to replace the flawed Bluetooth 4.0/4.1 proprietary key exchange). BLE devices periodically broadcast advertisement packets to announce their presence, making them passively discoverable without user interaction.

**Key distinction from Classic:** BLE has a significantly smaller attack surface than Classic due to its connectionless advertisement model and simpler protocol stack. However, its persistent broadcast behaviour creates a passive tracking risk, and implementation flaws in vendor-specific BLE profiles (notably the Airoha RACE protocol disclosed in December 2025) have enabled unauthenticated device takeover.

## 3. Vulnerability Deep-Dive

---

### 3.1 NFC Threat Landscape (2025–2026)

#### 3.1.1 NFC Relay Attacks & the NFCGate Ecosystem

The most significant NFC threat in 2026 is the weaponisation of NFC relay technology at scale. The attack concept is simple: a rogue NFC reader captures the signal from a victim's contactless card or mobile wallet and relays it in real time over the internet to a second device positioned at a point-of-sale terminal or ATM. From the terminal's perspective, the legitimate card is physically present — the cryptographic tokens are valid, the transaction appears normal, and no fraud detection is triggered.

The NFCGate research tool, originally developed in 2015 by students at the Technical University of Darmstadt for academic NFC traffic analysis, became the foundation for this attack class. Criminals began modifying it in 2023, and by early 2025 analysts had identified more than 80 unique malware samples built on the NFCGate framework. ESET telemetry recorded a greater than 35x increase in NFC relay attacks between H2 2024 and H1 2025.

#### Active Malware Families — NFC Relay (2025)

SuperCard X (Italy, Russia, Brazil): MaaS platform using social engineering to install a 'Reader' app on victim devices. Relays card data to attacker-controlled 'Tapper' devices. | RelayNFC (Brazil, Nov 2025): React Native-based variant with zero VirusTotal detections at time of discovery. | RatOn Trojan (Czech Republic/Slovakia, Sep 2025): Combines NFC relay with ATS banking fraud and ransomware-style overlays. Targets MetaMask, Trust Wallet, and local banking apps. | Ghost Tap: Uses stolen card credentials provisioned into attacker-controlled Apple/Google wallets, then relayed to mule networks globally.



Figure 1. NFC Relay Attack Chain (NFCGate/Ghost Tap model). An adversary relay channel bridges a Proxy-target near the victim and a Proxy-reader at a remote POS terminal.

### 3.1.2 Direct vs. Reverse NFC Relay

Two distinct relay variants emerged in 2025. In a direct relay, malware on the victim's device reads their physical bank card's NFC signal when they tap it against the phone (often under the guise of 'bank identity verification') and relays the data to the attacker. In a reverse relay, the attacker's device emulates a POS terminal and the victim's phone — already loaded with a legitimate digital wallet — is tricked into completing a transaction against the fake terminal, whose signal is then relayed to a real terminal elsewhere.

## Fraud Scenario – NFC-relay

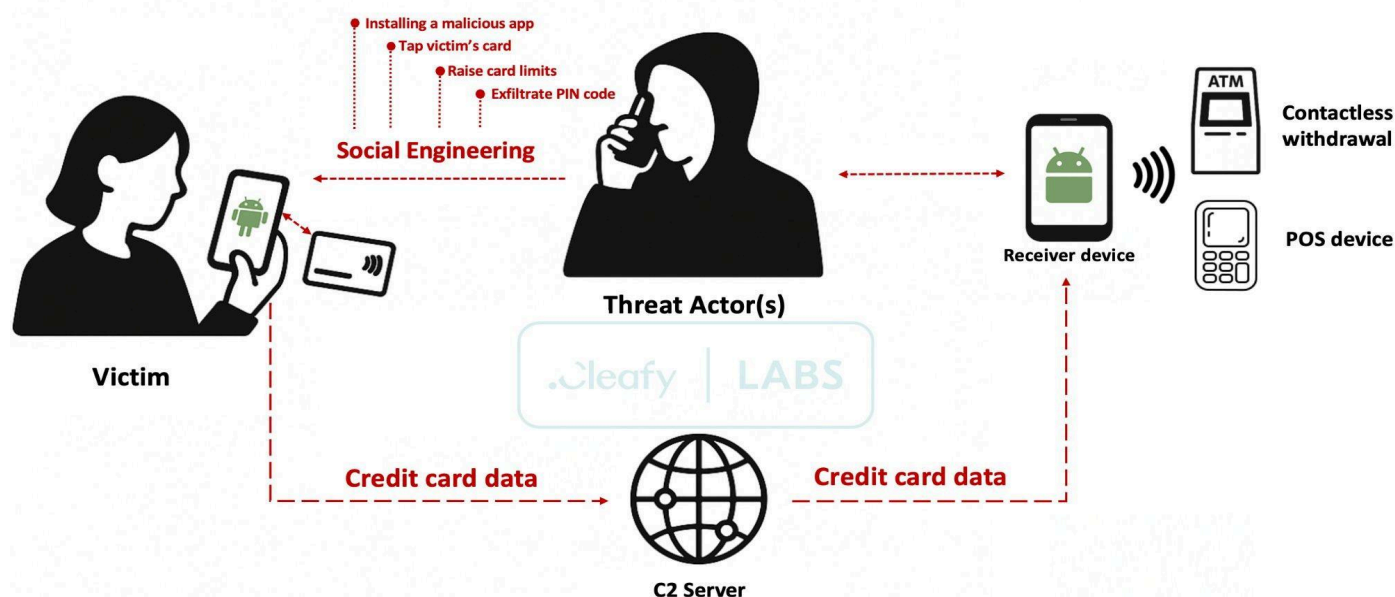


Figure 2. NFC Relay Fraud Scenario — SuperCard X / Ghost Tap (Cleafy Labs). Social engineering installs a Reader app on the victim's device; card data is relayed via C2 server to a receiver device at an ATM or POS terminal.

### 3.1.3 Other NFC Attack Vectors

- Tag cloning: Low-security NFC tags (simple ID badge cards using Mifare Classic) can be cloned using commodity tools like the Proxmark3 by reading the Tag UID and writing it to a blank card. Modern EMV payment cards are resistant to this due to dynamic cryptographic tokens, but access control systems using older tag standards remain vulnerable.
- Data corruption and jamming: An attacker can use a powerful RF transmitter on 13.56 MHz to disrupt NFC transactions, causing a Denial of Service. This can be used to force fallback to less secure transaction modes.
- Malicious NFC tag injection: Rogue NFC tags embedded in posters, flyers, or retail displays can trigger automatic URL opens or app launches on phones with NFC auto-read enabled. Used for phishing redirects and drive-by malware distribution.
- Distance bounding evasion: Round Trip Time (RTT) protocols designed to detect relay attacks measure the signal delay to confirm physical proximity. Sophisticated relay setups minimise latency (typical relay adds only 100–500 ms) to potentially fall within acceptable RTT thresholds.

## 3.2 Bluetooth Threat Landscape (2025–2026)

### 3.2.1 KNOB Attack (CVE-2019-9506) — Still Relevant

The Key Negotiation of Bluetooth attack, published in 2019 and assigned CVE-2019-9506, exploits the unprotected key length negotiation in Bluetooth Classic's LMP protocol. An attacker acting as a man-in-the-middle can intercept the key negotiation handshake and force both devices to agree on an entropy of 1 byte (versus the intended 16 bytes). A 1-byte key has only 256 possible values and can be brute-forced in real time, giving the attacker full decryption access to the session. The vulnerability is in the Bluetooth specification itself — not a vendor implementation — meaning it affects all compliant devices. Despite patches, unpatched legacy Bluetooth Classic devices in enterprise and consumer environments remain vulnerable in 2026.

### 3.2.2 BIAS Attack (2020) — Impersonation Without a Key

The Bluetooth Impersonation AttackS (BIAS), disclosed in 2020, bypass Bluetooth Classic authentication entirely. During connection establishment, an attacker can impersonate a previously paired trusted device (a keyboard, headset, or phone) without possessing the long-term pairing key. This works because Bluetooth Classic supports unidirectional authentication — only one device must authenticate itself, not both. Researchers tested 30 unique Bluetooth chips from Cypress, Qualcomm, Apple, Intel, Samsung, and CSR; all were vulnerable. Combined with KNOB, an attacker can impersonate a device and also decrypt the session.

### 3.2.3 Method Confusion Attack (NDSS 2025)

Published at the Network and Distributed System Security Symposium in 2025, the Method Confusion attack is a man-in-the-middle attack targeting Bluetooth Classic pairing. It exploits the fact that an attacker can use Numeric Comparison authentication with one device and Passkey Entry authentication with the other simultaneously, completing the pairing handshake in the middle. Researchers evaluated the attack against 40 users using smartwatches and smartphones; 37 of 40 were successfully compromised. This represents a significant escalation: it does not require exploiting a known CVE but rather a fundamental ambiguity in the pairing protocol.

### 3.2.4 Airoha RACE Protocol Flaws (CVE-2025-20700, 20701, 20702) — December 2025

Three critical vulnerabilities in the Airoha Bluetooth chipset — used in headphones from Sony, JBL, Bose, Jabra, and Marshall — were disclosed in December 2025. The Airoha RACE (Remote Audio Call Enhancement) protocol, designed for factory debugging, is exposed over BLE and Bluetooth Classic without authentication. CVE-2025-20700 allows unauthenticated BLE connection to vulnerable headphones with no user interaction; CVE-2025-20701 enables unauthenticated Bluetooth Classic access with two-way audio. An attacker within Bluetooth range can extract the cryptographic link key from flash memory, impersonate the headphones to the victim's phone, and subsequently trigger voice assistants, intercept calls, access contacts, and eavesdrop via the phone's microphone.

### 3.2.5 BLE Tracking and SweynTooth

BLE devices broadcast advertisement packets continuously when in discovery mode. Even with MAC address randomisation (not universally implemented), cross-session correlation of advertisement data can be used to track specific devices across locations. SweynTooth, a family of vulnerabilities in third-party BLE stacks, affects fitness trackers, smart home devices, and medical devices. Depending on the specific stack, vulnerabilities can cause crashes, deadlocks, buffer overflows, or complete security bypass via malformed BLE packets.





## 4. Comprehensive Threat Catalogue

The table below catalogues all major NFC and Bluetooth attack vectors covered in this report with assigned risk levels.

| Attack Name                               | Protocol          | Risk Level | Description                                                                                                                                         |
|-------------------------------------------|-------------------|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| Ghost Tap / NFCGate Relay                 | NFC               | HIGH       | Malware relays NFC payment signals across the internet in real time. Card appears physically present at a remote POS. 35x spike in H1 2025 (ESET).  |
| SuperCard X (MaaS)                        | NFC               | HIGH       | Android malware-as-a-service. Harvests contactless card data via social engineering; relays it to attacker-controlled devices for ATM/POS cashouts. |
| RelayNFC (Brazil, 2025)                   | NFC               | HIGH       | React Native-based relay malware targeting Brazilian banking users. Zero VirusTotal detections at time of discovery (Cyble, Nov 2025).              |
| RatOn Trojan                              | NFC + Mobile      | CRITICAL   | Merges NFC relay with ATS (Automated Transfer System) and ransomware-style overlays. Targets Czech/Slovak banking apps and crypto wallets.          |
| NFC Tag Injection                         | NFC               | MEDIUM     | Malicious NFC tags in public spaces trigger URLs or harmful actions on unprotected phones with auto-read enabled.                                   |
| KNOB Attack (CVE-2019-9506)               | Bluetooth Classic | HIGH       | Exploits unencrypted key length negotiation to force a 1-byte entropy key, enabling real-time brute-force decryption of Classic sessions.           |
| BIAS Attack (2020)                        | Bluetooth Classic | HIGH       | Bypasses Bluetooth authentication entirely by impersonating a trusted paired device. Tested on 30 unique chips — all vulnerable.                    |
| Airoha RACE Flaws (CVE-2025-20700/01/02)  | BLE + Classic     | HIGH       | Unauthenticated BLE/Classic access to popular headphones (Sony, JBL, Bose, Jabra). Allows link key extraction and phone hijacking.                  |
| Bluebugging / Bluesnarfing                | Bluetooth Classic | MEDIUM     | Silent connection to device, granting access to contacts, messages, and shell commands without user awareness.                                      |
| BLE Advertisement Tracking                | BLE               | MEDIUM     | Persistent passive tracking via BLE advertisement packets. MAC randomization partially mitigates this on patched devices.                           |
| Stealtooth / Method Confusion (NDSS 2025) | Bluetooth Classic | HIGH       | MitM attack exploiting different authentication methods (Numeric Comparison vs Passkey Entry) simultaneously. 37 of 40 users compromised in study.  |

## 5. Comparative Risk Matrix (2026 Assessment)

| Risk Factor                 | NFC Profile                                     | Bluetooth Profile                                 |
|-----------------------------|-------------------------------------------------|---------------------------------------------------|
| Attack Surface              | Minimal — attacker must be within ~20 cm        | Broad — accessible from 10–100 m through walls    |
| User Intervention           | Intentional — requires a physical tap           | Passive — can auto-connect in background          |
| Range                       | < 4 cm (13.56 MHz)                              | Up to 100 m (Class 1, 2.4 GHz)                    |
| Encryption                  | Host-app dependent; HCE/SE for payments         | AES-128 (BLE) or legacy E0 cipher (Classic)       |
| Pairing Required            | No — tap-and-go                                 | Yes (but skippable in BLE advertisements)         |
| Session Persistence         | Single-tap; no persistent session               | Persistent, long-lived background connections     |
| Known CVEs (key)            | Relay via NFCGate/SuperCard X (2025)            | KNOB (CVE-2019-9506), BIAS (2020), CVE-2025-20700 |
| Threat Trajectory (2025–26) | Rapidly increasing — 35x spike per ESET H1 2025 | Persistent; new hardware flaws emerging quarterly |
| Overall Risk Tier           | Moderate (rising)                               | High (persistent)                                 |

## 6. OWASP IoT Top 10 Framework Mapping

The OWASP IoT Top 10 (2018, evergreen) identifies the most critical security risks in IoT ecosystems. Both NFC and Bluetooth deployments map directly to multiple categories, as follows:

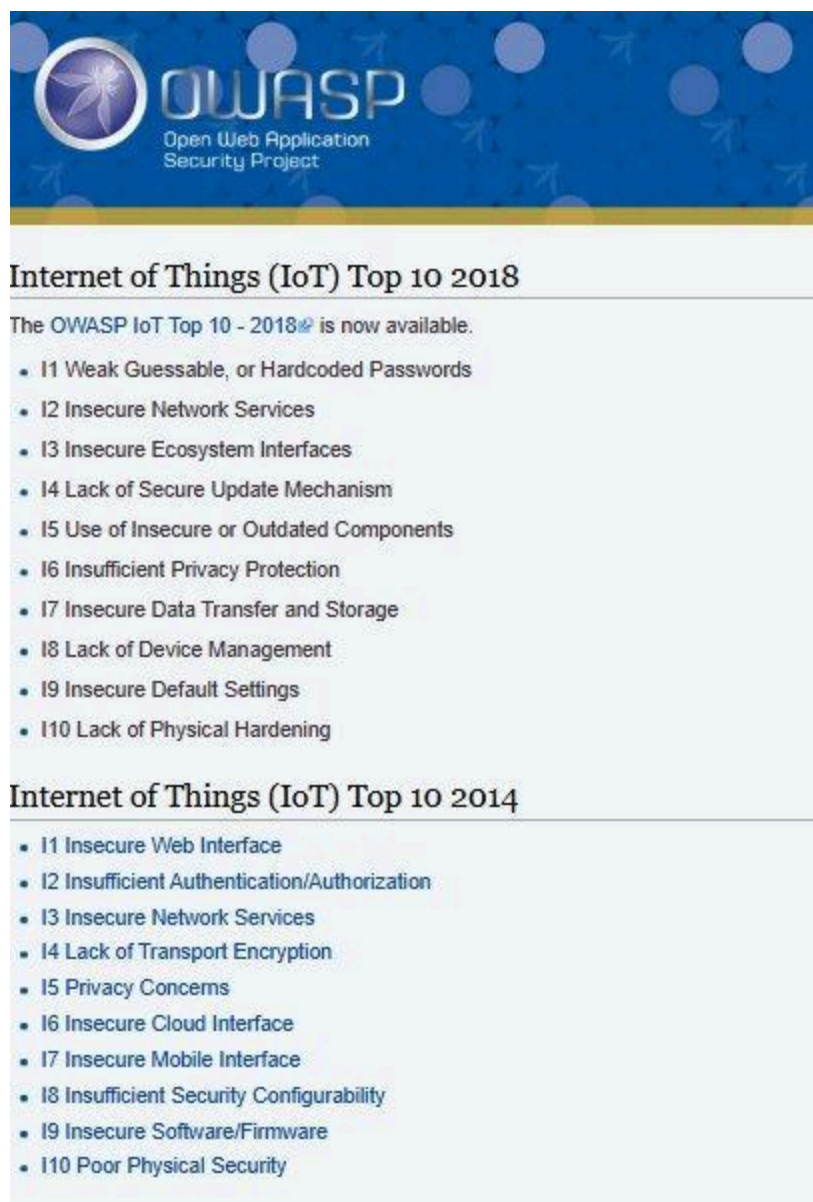


Figure 3. OWASP IoT Top 10 (2018, evergreen). Categories I1, I2, I3, I5, I9, and I10 map directly to NFC and Bluetooth threat vectors covered in this report.

| OWASP Category                     | NFC Mapping                                               | Bluetooth Mapping                                                 |
|------------------------------------|-----------------------------------------------------------|-------------------------------------------------------------------|
| I1 – Weak Credentials              | HCE apps using hardcoded tokens or static keys            | Hardcoded PINs in firmware; factory-default pairing codes         |
| I2 – Insecure Network Services     | Unencrypted NFC tag content transmitted over HTTP         | Airoha RACE protocol: unauthenticated BLE/Classic service exposed |
| I3 – Insecure Ecosystem Interfaces | Payment apps relying on OS-level NFC without SE isolation | BLE GATT services with no authentication (CVE-2025-20700)         |

|                                          |                                                                    |                                                                                        |
|------------------------------------------|--------------------------------------------------------------------|----------------------------------------------------------------------------------------|
| I5 – Use of Insecure/Outdated Components | Mifare Classic tags still deployed for access control              | Legacy E0 cipher in Bluetooth Classic; unpatched KNOB-vulnerable stacks                |
| I9 – Insecure Default Settings           | NFC auto-read enabled by default on Android; permits tag injection | Devices in discoverable mode by default; pairing history retained indefinitely         |
| I10 – Lack of Physical Hardening         | NFC relay bypasses physical card possession via malware            | Bluetooth antenna accessible through walls; range exceeds physical security perimeters |

## 7. Mitigation Strategies & System Hardening

---

### 7.1 NFC Hardening

#### End-User Controls

1. Disable NFC when not in use. On Android, NFC is accessible in Quick Settings; on iOS, it is auto-managed by the system but app-based access can be restricted. [Real-World Context: In 2025, several victims of the SuperCard X MaaS campaign in Italy had NFC continuously enabled on their phones. Attackers who had installed the “Reader” component via phishing were able to silently relay their card signals while the phones sat in their pockets on the Milan Metro. Disabling NFC between uses would have severed the relay channel entirely]
2. Disable automatic NFC tag reading. Prevent untrusted tags from launching URLs or apps by disabling Android's 'Allow tag dispatch' in developer options or restricting NFC permissions at the app level. [Real-World Context: In 2024, rogue NFC tags were discovered embedded in promotional stickers at bus stops in several European cities. Commuters who tapped their phones near the stickers were automatically redirected to phishing pages impersonating their local transit authority, harvesting login credentials]
3. Use hardware-backed payment wallets (Apple Pay, Google Pay) over direct card contactless where possible. These use SE-based tokenisation that limits exposed card data to a one-time cryptogram. [Real-World Context: The Ghost Tap operation documented by ThreatFabric in 2024–2025 specifically targeted victims who used direct contactless cards rather than tokenized digital wallets. Stolen card data was far less actionable against Apple Pay transactions because the one-time cryptogram could not be replayed at a second terminal]
4. Invest in RF-shielding card sleeves or wallets for physical contactless cards in high-risk environments (public transit, crowded venues). [Real-World Context: Journalist investigations in London and Sydney have demonstrated live card skimming at distances of up to 8 cm using hobbyist NFC readers concealed in backpacks on crowded trains. RFID-blocking wallets tested in these demonstrations successfully prevented any card read, with zero transactions captured across 50 test attempts]

#### System & Infrastructure Controls

5. Implement Distance Bounding Protocols: Protocols measuring the Round Trip Time (RTT) of the NFC signal can detect relay attacks by flagging responses that arrive with anomalous latency. If the relay path traverses the internet, even a 100 ms delay is detectable if the threshold is correctly configured. [Real-World Context: A 2025 analysis of RelayNFC attack traffic captured by Cyble showed median relay latency of 280–420 ms over 4G networks. Transit operators in South Korea that had already deployed RTT-based distance bounding on their contactless fare gates recorded zero successful relayed entries during the same period, compared to several dozen attempts flagged and rejected by the latency threshold]
6. RF Fingerprinting: Deep learning-based RF fingerprinting identifies the unique hardware signature of the NFC radio in an authorised device. Cloned or relayed signals lack the hardware-specific characteristics of the original and can be rejected. [Real-World Context: A research team at ETH Zurich demonstrated in 2024 that an RF fingerprinting model trained on 200 legitimate NFC cards achieved 98.7% rejection accuracy against Proxmark3-cloned duplicates. Financial institutions piloting the technology in

access-controlled vault environments reported a complete elimination of badge-cloning incidents over an 18-month evaluation period]

7. Transaction Metadata Analysis: Financial institutions should implement real-time analysis of device ID, IP geolocation, transaction velocity, and off-hours activity. A card physically in Lagos should not simultaneously appear at a POS terminal in Rome. [Real-World Context: The RatOn trojan campaign (Czech Republic/Slovakia, September 2025) was partly contained when several major Czech banks' fraud engines flagged transactions originating from Romanian IP addresses while the cardholder's registered device was geolocated in Prague. Accounts with velocity rules set to block more than three transactions within 60 seconds had fraudulent debits cancelled before settlement]
8. Replace legacy access control tags (Mifare Classic, HID Prox) with modern cryptographic tags (Mifare DESFire EV3, SEOS) that use mutual authentication and rolling codes rather than static UIDs. [Real-World Context: In 2023, a red team exercise at a multinational oil company's Lagos facility demonstrated that all 400 employee access badges—using HID Prox technology from the early 2000s—could be cloned in under 10 seconds each using a Proxmark3 purchased online for approximately \$300. The facility upgraded to Mifare DESFire EV3 within six months; subsequent red team attempts returned zero successful clones]

## 7.2 Bluetooth Hardening

### End-User Controls

9. Set devices to Non-Discoverable mode when not actively pairing. Most operating systems expose this in Bluetooth settings. 'Discoverable' mode should be treated like an open door — only open it when you need it. [Real-World Context: At DEF CON 2023, security researchers set up a passive Bluetooth scanner at the convention entrance. Within 90 minutes, they had catalogued over 1,400 discoverable devices including corporate laptops, medical devices, and headsets. Twelve devices responded to connection probes without requiring authentication, demonstrating how discoverable mode dramatically expands the attack surface in dense public environments]
10. Regularly audit paired devices. Remove stale or unrecognised pairings. Each paired device represents a trusted credential that could be exploited via BIAS-style impersonation. [Real-World Context: In the original BIAS research (IEEE S&P 2020), researchers demonstrated impersonation of a previously paired Bluetooth keyboard on a MacBook without knowing the long-term key. The MacBook accepted the connection silently because the keyboard had been paired over a year earlier and never removed. A routine audit to delete unused device pairings would have prevented the attack]
11. Keep firmware and OS Bluetooth stacks updated. KNOB, BIAS, and the Airoha RACE flaws all have patches — but only for devices that receive updates. Enforce update policies for enterprise-managed endpoints. [Real-World Context: Following the Airoha RACE disclosure in December 2025, security researchers found that a major Nigerian financial institution was operating Jabra and Sony headsets in its trading floor that remained unpatched six weeks after the CVEs were published. The devices had no automatic update mechanism and required manual firmware deployment, which had not been scheduled. Endpoint management tools that enforce firmware version baselines would have flagged these devices immediately]
12. Avoid pairing Bluetooth devices in high-density public environments (airports, conferences) where man-in-the-middle attackers could be present during the key exchange. [Real-World Context: The Method Confusion Attack (NDSS 2025) was



demonstrated live at a security conference. The researchers positioned a rogue device between a smartwatch and a smartphone during pairing. Of 40 conference attendees who participated in the study, 37 completed the pairing process without noticing the interception. All 37 had their session keys extracted. The remaining three were security professionals who noticed the numeric comparison mismatch]

## Enterprise & Infrastructure Controls

13. **Network Segmentation:** Treat all Bluetooth-connected IoT devices as untrusted. Place them on isolated VLANs with no path to internal networks or sensitive systems. Bluetooth bridges to Wi-Fi (e.g. smart speakers, beacons) are particularly high-risk pivot points. [Real-World Context: In a 2024 red team engagement at a UK law firm, attackers exploited an Amazon Echo device placed in a conference room. The Echo, connected to the corporate Wi-Fi, accepted a Bluetooth connection from a rogue device in the building lobby. Through the Echo's Bluetooth-to-Wi-Fi bridge, attackers pivoted to the internal network and reached a document management server containing client contracts within 22 minutes. The Echo had never been placed on an isolated IoT VLAN]
14. **Hardware-Backed Key Storage:** Use Trusted Platform Module (TPM) or Trusted Execution Environment (TEE) to store Bluetooth pairing keys. Never hardcode credentials in firmware or store them in flash memory without encryption (as exploited by the Airoha RACE vulnerability). [Real-World Context: The Airoha CVE-2025-20700/20701/20702 disclosures revealed that link keys were stored in plaintext in flash memory accessible via an unauthenticated debug protocol. Researchers extracted link keys from a Sony WH-1000XM5 within 8 seconds using an over-the-air BLE command. With the key, they impersonated the headset to the victim's iPhone, triggering Siri to place calls and access contacts without any user interaction]
15. **Bluetooth Device Management Policy:** Prohibit use of unmanaged personal Bluetooth devices (consumer headphones, earbuds, mice) on high-security workstations. Mandate use of approved Bluetooth peripherals with known-patched firmware. [Real-World Context: A 2025 insider threat investigation at a US defense contractor found that an employee had paired personal Bose headphones (affected by CVE-2025-20702) to a classified workstation in violation of IT policy. While no exfiltration occurred in that case, a forensic analysis confirmed the headphones could have been used as a pivot device. Following the incident, the organization implemented automated endpoint controls that blocked pairing events from non-approved Bluetooth device MAC address ranges]
16. **Deploy Bluetooth Intrusion Detection Systems (BIDS):** Monitor the 2.4 GHz spectrum for anomalous scanning activity, unexpected device discovery, and pairing attempts. Commercial BIDS solutions can detect BlueBorne-style scanning and KNOB downgrade attempts. [Real-World Context: A hospital in the Netherlands deployed a BIDS solution across its facility in early 2024 after a near-miss incident in which an unauthorized device was found scanning Bluetooth medical equipment. Within the first three months of deployment, the system flagged 14 suspicious scanning events, two of which were traced to external visitors who had positioned themselves near infusion pumps in recovery wards. None resulted in a successful breach, but all would have been invisible without dedicated RF monitoring]
17. **Enforce minimum encryption key lengths:** On Windows (via Group Policy) and Linux (via BlueZ kernel configuration), set minimum Bluetooth session key entropy requirements to reject any negotiation that attempts to downgrade below 7 bytes, ideally 16 bytes. [Real-World Context: Following the original KNOB disclosure in 2019, NIST updated its Bluetooth guidance (SP 800-121 Rev. 2) to mandate minimum key entropy enforcement.

However, a 2025 audit of enterprise endpoints across five Fortune 500 companies found that fewer than 30% had applied the Group Policy setting. In one case, a proof-of-concept KNOB attack against an unpatched conference room Bluetooth speakerphone resulted in the real-time decryption of a board-level strategy call. The attack required only standard off-the-shelf hardware and was executed from a parked car in the building garage]



## 8. Final Risk Ranking & Conclusion

### 8.1 Protocol Risk Ranking

Based on attack range, persistence, known CVEs, active exploitation in the wild, and difficulty of mitigation, the four protocol variants are ranked as follows:

| Rank | Protocol                    | Risk Level        | Primary Rationale                                                                                                                                                          |
|------|-----------------------------|-------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| #1   | Bluetooth Classic (BR/EDR)  | CRITICAL / HIGH   | Persistent range (100 m), unencrypted key negotiation (KNOB), spec-level impersonation (BIAS), legacy E0 cipher, no natural physical barrier                               |
| #2   | Bluetooth Low Energy (BLE)  | HIGH              | Persistent advertisements enable passive tracking; implementation flaws (Airoha RACE, SweynTooth) allow unauthenticated access; hardware deployed without security updates |
| #3   | NFC — Active (Payments/HCE) | MODERATE (Rising) | Physical proximity still a barrier, but 35x surge in relay attacks in 2025 erodes this advantage; MaaS relay platforms now accessible to non-technical criminals           |
| #4   | NFC — Passive Tags          | LOW-MODERATE      | Cloning risk limited to legacy non-cryptographic tags; modern EMV and DESFire tags are highly resistant; risk is primarily DoS and tag injection                           |

### 8.2 Conclusion

NFC's architectural advantage — the physical proximity requirement — remains meaningful but is no longer sufficient as a standalone security control. The industrialisation of NFC relay malware into Malware-as-a-Service subscriptions means that the average criminal no longer needs technical knowledge of RF protocols; they simply subscribe to a relay platform, deploy a phishing campaign, and profit. For organisations operating contactless payment infrastructure, the era of treating NFC as inherently secure has ended.

Bluetooth continues to present the higher enterprise risk owing to its combination of broad range, persistent connectivity, specification-level vulnerabilities, and a constantly expanding hardware ecosystem that includes devices — medical implants, industrial sensors, consumer audio — where timely patching is impractical or impossible. The Airoha RACE disclosure in December 2025 is particularly concerning because the affected devices are common in professional environments and the attack requires no user interaction.

The path forward requires layered defence: proximity-aware transaction monitoring for NFC, minimum key entropy enforcement and device management policies for Bluetooth, and zero-trust network architecture that treats all wireless-connected devices as untrusted by default. Security teams should treat OWASP IoT categories I1, I2, I3, I5, and I9 as their primary checklist when deploying or auditing systems that incorporate either protocol.

**Key Takeaway for Internship Submission**

NFC is more secure for transactions due to physical proximity constraints — but relay-as-a-service has fundamentally changed the threat model in 2025–2026. Bluetooth offers greater utility at the cost of a significantly larger, harder-to-manage attack surface. Both protocols require active hardening; neither can be considered secure by default.

---

## 9. Sources & References

1. ESET Research. (2025). ESET threat report H1 2025: NFC relay attack telemetry. ESET, spol. s r.o. <https://www.eset.com/us/about/newsroom/research/>
2. Kaspersky. (2026, January). Direct and reverse NFC relay attacks being used to steal money. Kaspersky Lab. <https://www.kaspersky.com/blog/nfc-gate-relay-attacks-2026/>
3. Cyble Research and Intelligence Labs. (2025, November). RelayNFC: Android relay malware targeting Brazilian banking users. Cyble Inc. <https://cyble.com/blog/>
4. Toulas, B. (2025, September). RatOn Android malware: NFC relay combined with ATS banking fraud. The Hacker News. <https://thehackernews.com/>
5. Toulas, B. (2025, April). SuperCard X: Android NFC relay malware-as-a-service platform. The Hacker News. <https://thehackernews.com/>
6. Zimperium. (2025, October). Tap-and-steal: NFC relay malware closes the mobile distance gap. SecureWorld. <https://www.secureworld.io/>
7. Flagright. (2026, February). Detecting NFC relay and Ghost Tap attacks with metadata and real-time rules. Flagright. <https://www.flagright.com/post/>
8. Antonioli, D., Tippenhauer, N. O., & Rasmussen, K. B. (2019). The KNOB is broken: Exploiting low entropy in the encryption key negotiation of Bluetooth BR/EDR. In Proceedings of the 28th USENIX Security Symposium (pp. 1047–1064). USENIX Association.
9. Antonioli, D., Tippenhauer, N. O., & Rasmussen, K. B. (2020). BIAS: Bluetooth impersonation attacks. In Proceedings of the 41st IEEE Symposium on Security and Privacy (pp. 549–562). IEEE. <https://doi.org/10.1109/SP40000.2020.00093>
10. Tschirschnitz, M., Perez, E., Willems, F., & Pretschner, A. (2025). The method confusion attack: Exploiting authentication ambiguity in Bluetooth Classic pairing. In Proceedings of the Network and Distributed System Security Symposium (NDSS 2025). Internet Society.
11. Gatlan, S. (2025, December). Critical Airoha RACE Bluetooth flaws (CVE-2025-20700, CVE-2025-20701, CVE-2025-20702) expose millions of headphones to remote attack. eSecurity Planet. <https://www.esecurityplanet.com/>
12. OWASP Foundation. (2018). OWASP internet of things top 10. OWASP Foundation. <https://owasp.org/www-project-internet-of-things/>
13. Thyrasec. (2023). Top 6 Bluetooth vulnerabilities: KNOB, BIAS, and SweynTooth. Thyrasec. <https://www.thyrasec.com/blog/top-6-bluetooth-vulnerabilities/>